Information Security CSC232

LECTURE-3 21-SEPT-2026

SAAD MALIK

Lecture Contents

- Purpose and importance of security planning
- Identifying assets, threats, requirements, and objectives
- Selecting security controls
- Policy fundamentals
- Enterprise Information Security Policy (EISP)
- Issue-Specific Security Policy (ISSP)
- System-Specific Security Policy (SysSP)
- Acceptable Use Policy (AUP)
- Password, Email, Remote Access, and Mobile Device Policies
- Security standards (ISO 27001, NIST CSF, PECA)
- Security awareness and training
- Business continuity and disaster recovery
- Backup strategies

The Opening Scenario

!

Charlie's Nightmare

"Charlie Moody flipped his jacket collar up to cover his ears. The spray blowing over him from the fire hoses was icing the cars that lined the street where he stood watching his office building burn."

Questions to Consider:

- Where were the network design diagrams?
- Had the off-site backup tapes been tested?
- Where was the contact information for key personnel?

The Lesson:

"Begin with the end in mind."

"— Stephen Covey"

Planning is not optional — it is the foundation of survival.

Purpose of Security Planning

Without Planning:

- No direction or priorities
- Reactive instead of proactive
- Resources wasted on wrong controls
- Inconsistent security posture
- Legal and compliance risks

With Planning:

- Clear goals and objectives
- Efficient resource allocation
- Consistent, measurable security
- Legal compliance
- Business continuity assurance

Real-World Example:
Hurricane Katrina (2005)

- Organizations with disaster recovery plans recovered in days
- Organizations without plans took months or never recovered
- Lesson: Planning determines survival

The Three Levels of Planning

STRATEGIC	5–10 YEARS	**Where do we want to be?** Set direction, vision, mission
TACTICAL	1–2 YEARS	**How do we get there?** Break goals into projects
OPERATIONAL	DAY-TO-DAY	**What do we do today?** Tasks, schedules, procedures

Real-World Example:
University IT Department

- **Strategic:** "Provide 99.9% uptime for all critical systems by 2027"
- **Tactical:** "Implement redundant servers and backup systems by Q4 2026"
- **Operational:** "Daily backup checks at 8:00 AM, weekly restoration tests on Fridays"

Information Security Governance

"Governance is the set of responsibilities and practices exercised by the board and executive management with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risks are managed appropriately and verifying that the enterprise's resources are used responsibly."

Goal	Description	Example
Strategic Alignment	Align security with business strategy	Security supports online banking goals
Risk Management	Manage and mitigate threats	Regular risk assessments
Resource Management	Efficient use of security resources	Optimize security budget
Performance Measurement	Measure and report metrics	Track incident response times
Value Delivery	Optimize security investments	Cost-benefit analysis of controls

Governance in Practice



Real-World Example: Target Breach (2013)

- Board was not informed of security risks
- Security team's warnings were ignored
- Result: 40 million credit cards stolen, CEO resigned
- Lesson: Governance failure at the top leads to disaster

Identifying Assets

Category	Examples	Security Priority
Data	Customer records, financial data, IP	Critical
Hardware	Servers, laptops, network devices	High
Software	Applications, operating systems	High
People	Employees, contractors, customers	High
Procedures	Policies, documentation	Medium
Networks	Infrastructure, connections	High

Asset Identification Questions:

- What information do we have?
- Where is it stored?
- Who has access to it?
- What is it worth?
- What happens if it's lost?

Asset Valuation

Criteria	Description	Example
Replacement Cost	Cost to replace asset	New server = PKR 500,000
Revenue Impact	Revenue dependent on asset	E-commerce site = PKR 1M/day
Legal Requirements	Regulatory obligations	HIPAA, GDPR compliance
Reputation Impact	Damage to brand	Data breach = lost customers
Competitive Advantage	Unique value	Trade secrets, patents

Yahoo Data Breach (2013-2014)

- Asset: User database (3 billion accounts)
- Value: $350 million reduction in acquisition price
- Lesson: Asset value includes reputation and legal liability

Identifying Threats

THREAT CATEGORIES
HUMAN THREATS • Hackers, insiders, social engineers • Terrorists, competitors, activists
NATURAL THREATS • Fire, flood, earthquake, hurricane • Power outages, extreme temperatures
TECHNICAL THREATS • Malware, DoS attacks, software bugs • Hardware failures, network outages
PHYSICAL THREATS • Theft, vandalism, unauthorized access • Environmental hazards

Real-World Example: WannaCry Ransomware (2017)

- Threat: Malware exploiting SMB vulnerability
- Impact: 200,000+ computers in 150 countries
- Lesson: Threats evolve; planning must be ongoing

Identifying Requirements

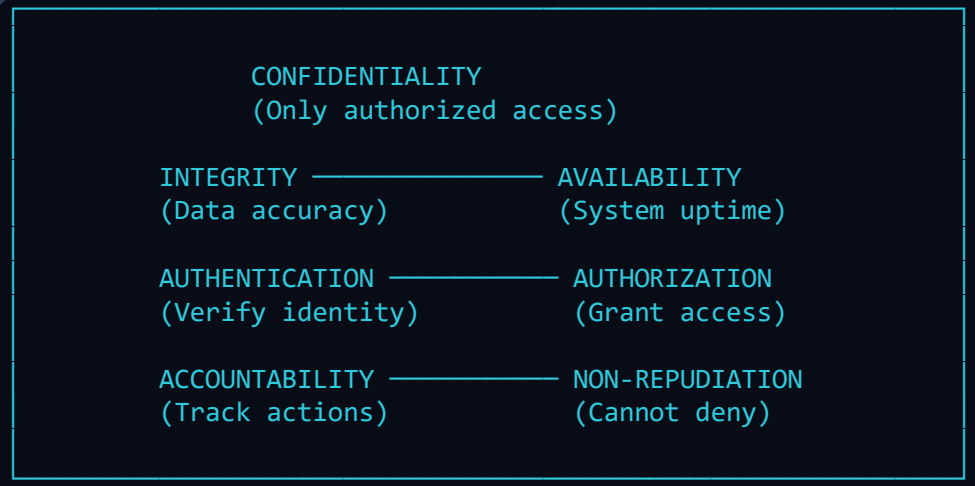
Requirement Type	Description	Examples
Legal	Laws and regulations	PECA 2016, GDPR, HIPAA
Contractual	Agreements with partners	Service Level Agreements
Industry Standards	Best practices	ISO 27001, PCI-DSS
Organizational	Internal policies	Company security policy
Customer	User expectations	Privacy, availability

PECA 2016 (Pakistan)

- Requirement: Protect against unauthorized access
- Impact: Organizations must implement security controls
- Penalty: Fines and imprisonment for violations
- Lesson: Legal requirements drive security planning

Setting Security Objectives

Core Security Objectives:



Real-World Example: Online Banking System

- Confidentiality: Encrypt all transactions
- Integrity: Verify account balances
- Availability: 99.99% uptime
- Authentication: Multi-factor login
- Authorization: Role-based access
- Accountability: Audit all transactions

Selecting Security Controls

Control Type	Description	Examples
Preventive	Stop attacks before they happen	Firewalls, encryption
Detective	Detect attacks in progress	IDS, logs, audits
Corrective	Fix damage after attack	Backups, patches
Deterrent	Discourage attackers	Warning banners, guards
Compensating	Alternative controls	Manual procedures



Cost-Benefit Analysis

```
CBA = ALE(prior) - ALE(post) - ACS

Where:
- ALE(prior) = Annual Loss Expectancy before control
- ALE(post) = Annual Loss Expectancy after control
- ACS = Annual Cost of Safeguard
```

Real-World Example:

SQL Injection Prevention

Item	Value
ALE(prior)	PKR 2,500,000
Control	Web Application Firewall
ACS	PKR 500,000
ALE(post)	PKR 250,000
CBA	PKR 1,750,000

Decision: Implement the control (positive CBA)

What is a Security Policy?

Policy vs. Law:

Aspect	Policy	Law
Source	Organization	Government
Enforcement	Internal	External
Ignorance	Acceptable defense	Not acceptable
Penalty	Disciplinary	Legal

"An Information Security Policy (ISP) is a formal, written statement approved by senior management that establishes the organization's approach to protecting its information assets. It defines the rules, responsibilities, and expected behaviors for all employees, contractors, and third parties regarding the confidentiality, integrity, and availability of information.."

Policy Characteristics:

- Organizational laws – Define acceptable/unacceptable behavior
- Management tool – Guides security efforts
- Least expensive control – Only requires time and effort
- Most difficult to implement – Requires enforcement

Policy Hierarchy



Real-World Example: Password Policy Hierarchy

- Policy: "Strong passwords are required"
- Standard: "Minimum 12 characters, mixed case, numbers, symbols"
- Procedure: "Click Start → Settings → Change Password → Enter new password"
- Guideline: "Consider using a password manager"

Policy Effectiveness Criteria

Criterion	Description	Implementation
Dissemination	Available to all employees	Email, intranet, handbook
Review	Read and understood	Sign-off, quizzes
Comprehension	Understood by all	Training, translations
Compliance	Agreed to comply	Signed acknowledgment
Enforcement	Uniformly applied	Consistent penalties

Arthur Andersen/Enron Scandal (2001)

- Policy existed for document retention
- Policy was not consistently enforced
- Result: Obstruction of justice, company destroyed
- Lesson: Unenforced policies are worse than no policies

Enterprise Information Security Policy (EISP)

Component	Description
Statement of Purpose	What is this policy for?
Information Security Elements	Definition of security
Need for Security	Why is security important?
Responsibilities and Roles	Who does what?
References	Related standards and laws

"The EISP is based on and directly supports the mission, vision, and direction of the organization and sets the strategic direction, scope, and tone for all security efforts."

- Executive-level document — Drafted by CIO/CISO
- Short — Usually 2-10 pages
- Strategic — Sets direction, not details
- Stable — Modified only when strategy changes

EISP Real-World Example

```
UNIVERSITY INFORMATION SECURITY POLICY
======================================

1. PURPOSE
   This policy establishes the requirements for protecting
   university information assets.

2. SCOPE
   All students, faculty, staff, contractors, and visitors.

3. POLICY STATEMENTS
   3.1 Access Control
   3.2 Password Policy
   3.3 Data Classification
   3.4 Incident Response

4. RESPONSIBILITIES
   - CIO: Overall security program
   - CISO: Day-to-day management
   - Managers: Ensure compliance
   - Users: Follow policies

5. ENFORCEMENT
   Violations may result in disciplinary action.

6. REVIEW
   Annual review and update.
```

Issue-Specific Security Policy (ISSP)

"The ISSP (1) addresses specific areas of technology, (2) requires frequent updates, and (3) contains a statement on the organization's position on a specific issue."

Common ISSP Topics:

- Email usage
- Internet usage
- Social media
- Mobile devices
- Remote access
- Software Installation
- USB Drives
- Cloud Services

Three Approaches:

Approach	Description	Pros/Cons
Independent	Separate policy for each issue	Flexible, but may miss issues
Comprehensive	Single policy covering all	Complete, but overgeneralizes
Modular	Separate modules, centrally managed	Best of both worlds

ISSP Components

Component	Description	Example
Statement of Policy	Scope, applicability, responsibilities	"This policy covers email usage"
Authorized Access	Who can use, what for	"Only employees for business purposes"
Prohibited Use	What is not allowed	"No personal use, no harassment"
Systems Management	Monitoring, storage, security	"Emails may be monitored"
Violations	Reporting and penalties	"Report to security@company.com"
Review	Schedule and process	"Annual review by CISO"
Liability	Legal disclaimers	"Company not liable for misuse"

Real-World Example:
Email Usage Policy

- Authorized: Business communication, customer contact
- Prohibited: Personal use, offensive content, spam
- Monitoring: Company reserves right to monitor
- Penalties: Warning, suspension, termination

System-Specific Security Policy (SysSP)

"SysSPs often function as standards or procedures to be used when configuring or maintaining systems."

Two Types:

Type	Description	Audience
Managerial Guidance	Management intent for technology	Managers, administrators
Technical Specifications	Detailed configuration instructions	System administrators

Implementation Methods:

Access Control Lists (ACLs):

File: /shared/finance/reports.xlsx

Owner: CFO

Permissions:

- CFO: Read, Write, Delete

- Finance Manager: Read, Write

- Finance Staff: Read

- Everyone Else: No Access

Configuration Rules:

Firewall Rule:

- Source: Any

- Destination: 192.168.1.10 (Web Server)

- Port: 80, 443

- Action: Allow

- Log: Yes

Acceptable Use Policy (AUP)

"The AUP defines acceptable and unacceptable use of organizational computing resources."

Key Elements:

Element	Description	Example
Permitted Use	What is allowed	"Academic and administrative tasks"
Prohibited Use	What is not allowed	"Illegal activities, harassment"
User Responsibilities	What users must do	"Report security incidents"
Monitoring	What company can monitor	"All activity may be logged"
Consequences	What happens if violated	"Disciplinary action"

Example: University ACCEPTABLE USE POLICY

PERMITTED:

- Academic research and coursework

- Administrative tasks

- Approved communication

PROHIBITED:

- Commercial activities

- Downloading copyrighted material

- Accessing offensive content

- Sharing passwords

ACKNOWLEDGMENT:

I have read and agree to comply.

Password Policy

Policy Components:

Component	Requirement	Rationale
Length	Minimum 12 characters	Resist brute force
Complexity	Upper, lower, numbers, symbols	Increase keyspace
Expiration	Every 90 days	Limit exposure
History	No reuse of last 5	Prevent cycling
Lockout	After 5 failed attempts	Prevent brute force
Storage	Hashed and salted	Protect database

Google Password Policy (2023)

- Minimum 8 characters (but recommends 12+)
- No expiration if 2FA is enabled
- Breach detection and alerts
- Lesson: Balance security with usability
- Writing passwords on sticky notes

Email Policy

Policy Components:

Area	Policy Statement	Example
Use	Business purposes only	No personal shopping
Confidentiality	No sensitive data in email	Encrypt attachments
Attachments	Size and type limits	Max 10MB, no .exe
Monitoring	Company reserves right	"Emails may be reviewed"
Retention	How long to keep	7 years for business records
Signature	Required format	Name, title, contact

Hillary Clinton Email Controversy (2015)

- Used personal email for government business
- Issue: Violation of records retention policies
- Lesson: Email policies must be clear and enforced

Best Practices:

- Use encryption for sensitive data
- Avoid clicking suspicious links
- Report phishing attempts
- Use auto-signatures with disclaimers

Remote Access Policy

Policy Components:

Component	Requirement	Rationale
Authorization	Manager approval required	Control access
Authentication	Multi-factor required	Strong verification
Encryption	VPN required	Secure transmission
Devices	Company-approved only	Manage security
Monitoring	Activity logged	Detect anomalies
Termination	Access revoked immediately	Prevent unauthorized

Colonial Pipeline (2021)

- Attack: Compromised VPN password
- Impact: $4.4 million ransom, fuel shortage
- Lesson: Remote access requires MFA

Technical Controls:

- VPN with strong encryption
- Multi-factor authentication
- Endpoint security software
- Network access control (NAC)

Mobile Device Policy

Approach	Description	Control Level
BYOD	Bring Your Own Device	Low (user-owned)
COPE	Corporate Owned, Personally Enabled	Medium
COBO	Corporate Owned, Business Only	High
CYOD	Choose Your Own Device	Medium

Policy Components:

Area	Requirement	Example
Enrollment	Register with IT	MDM enrollment
Passcode	Strong PIN required	Minimum 6 digits
Encryption	Device encryption	AES-256
Remote Wipe	IT can erase	Lost/stolen device
Apps	Approved apps only	Company app store
Updates	Keep current	Automatic updates

Mobile Device Policy - Real World

Best Practices:

1. Clear policy on what is monitored
2. Separate work and personal data
3. Require encryption
4. Enable remote wipe
5. Regular security updates
6. Employee training

Case Study: IBM BYOD Program

Policy:
- Employees can use personal devices
- Must enroll in MDM
- Must have passcode
- Must allow remote wipe

Benefits:
- Increased productivity
- Employee satisfaction
- Cost savings

Challenges:
- Privacy concerns
- Data leakage risk
- Support complexity

Security Standards Overview

International Frameworks

What are Security Standards?

- A security standard is a specific set of requirements, rules, or controls that must be followed to achieve a certain level of security.
- Documented agreements containing technical specifications
- Best practices for security management
- Certification criteria for organizations

Standard	Focus	Origin
ISO/IEC 27001	Information Security Management	International
NIST CSF	Cybersecurity Framework	United States
PECA 2016	Electronic Crimes Prevention	Pakistan
PCI-DSS	Payment Card Security	Industry
GDPR	Data Privacy	European Union

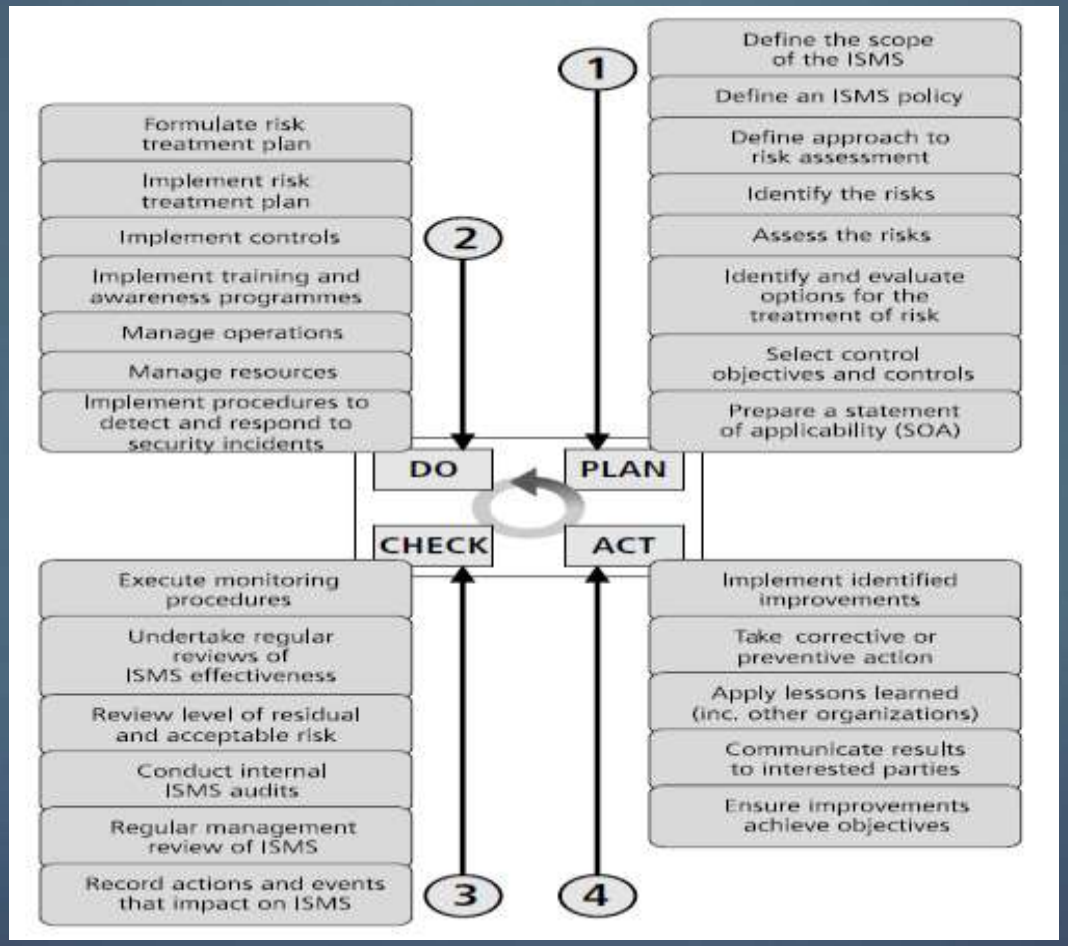
Other Relevant Laws / Standards / Bodies:

- CERT Rules, 2023:
- Electronic Transactions Ordinance (ETO), 2002
- National Cyber Security Policy, 2021:
- Pakistan Information Security Framework (PISF 2026):
- Pakistan Security Standards (PSS) for Cryptographic & IT Security
- State Bank of Pakistan (SBP) Cybersecurity Framework:
- Pakistan Penal Code (PPC)
- National Cyber Crime Investigation Agency (NCCIA)

ISO/IEC 27001

Information Security Management System

"ISO/IEC 27001 provides information on how to implement ISO/IEC 27002 and how to set up an information security management system (ISMS)."



ISO 27001 - Real World Example

Certification Benefits
Case Study: Financial Institution

Before Certification:
- Inconsistent security practices
- No formal risk assessment
- Unclear responsibilities
- Customer concerns about security

After Certification:
- Documented security management system
- Regular risk assessments
- Clear roles and responsibilities
- Competitive advantage in market

Business Impact:
- 40% reduction in security incidents
- 25% increase in customer confidence
- Compliance with regulatory requirements
- Improved incident response times

Key Takeaway:
ISO 27001 provides a systematic approach to managing security risks.

NIST Cybersecurity Framework



NIST CSF: a flexible lifecycle for managing cybersecurity risk

NIST CSF - Real World Application

Small Business Assessment:

Function	Current State	Gap	Action
Identify	Excel asset list	No formal process	Implement asset management
Protect	Passwords only	No MFA	Deploy MFA
Detect	No monitoring	No visibility	Install IDS
Respond	Ad-hoc	No plan	Create IR plan
Recover	Weekly backups	Not tested	Test restoration

Priority Actions:

1. Create formal asset inventory
2. Implement multi-factor authentication
3. Deploy intrusion detection
4. Develop incident response plan
5. Test backup restoration

Key Takeaways: NIST CSF provides a flexible framework for organizations of all sizes.

PECA 2016 (Pakistan)

"An Act to prevent cyber crimes and to provide for related matters."

Key Provisions:

Section	Offense	Penalty
3	Unauthorized access	Up to 3 months, PKR 50,000
4	Unauthorized copying	Up to 6 months, PKR 100,000
5	Interference with system	Up to 2 years, PKR 500,000
6	Unauthorized data modification	Up to 3 years, PKR 1,000,000
7	Data damage	Up to 5 years, PKR 5,000,000
10	Cyber terrorism	Up to 14 years, PKR 50,000,000

2025 Amendments:

- Increased penalties for critical infrastructure attacks
- Enhanced provisions for data protection
- New provisions for AI-related crimes

PECA - Real World Implications

What Organizations Must Do:

Requirement	Description	Implementation
Security Controls	Protect systems from unauthorized access	Firewalls, encryption
Data Protection	Protect personal data	Encryption, access controls
Incident Reporting	Report cyber crimes	Notify authorities
Record Keeping	Maintain logs	90-day retention minimum
Cooperation	Assist investigations	Designate contact person

Case Study: Pakistani Bank
Challenge: Comply with PECA while serving customers
Actions Taken:

- Implemented multi-factor authentication
- Encrypted all customer data
- Established incident response team
- Created PECA compliance policy
- Trained staff on legal requirements

Result: Enhanced security, regulatory compliance

Common Security Practices

Essential Practices:

Practice	Description	Why It Matters
Strong Passwords	Complex, unique, changed regularly	Prevents unauthorized access
Email Security	Verify senders, don't click links	Prevents phishing
Internet Use	Avoid risky sites, use HTTPS	Prevents malware
Backups	Regular, tested, offsite	Ensures recovery
Updates	Automatic, timely	Patches vulnerabilities

Real-World Example:
Equifax Breach (2017)

- Cause: Unpatched vulnerability (Apache Struts)
- Impact: 147 million records exposed
- Cost: $1.4 billion+
- Lesson: Regular updates prevent known exploits

Password Best Practices

The Do's and Don'ts:

Do	Don't
Use 12+ characters	Use dictionary words
Mix character types	Use personal information
Use unique passwords	Reuse passwords
Use a password manager	Write on sticky notes
Enable MFA	Share with others

Password Strength Comparison:

Password	Time to Crack	Strength
password123	Instant	Very Weak
P@ssw0rd	2 hours	Weak
Tr0ub4dor&3	3 days	Medium
CorrectHorseBatteryStaple	550 years	Strong
7K#mP9$vL2@nQ	3 million years	Very Strong

Real-World Example:

RockYou Breach (2009)

- 32 million passwords exposed
- Top passwords: 123456, password, 12345
- **Lesson:** Weak passwords are everywhere

Email Security Best Practices

Common Email Threats:

Threat	Description	Example
Phishing	Fake emails to steal credentials	Fake bank email
Malware	Malicious attachments	Infected Word doc
Spoofing	Forged sender address	CEO fraud
Spam	Unsolicited commercial email	Weight loss ads

Best Practices:

1. Verify sender addresses before opening
2. Hover over links to see actual URL
3. Don't open unexpected attachments
4. Use encryption for sensitive data
5. Report suspicious emails
6. Never share credentials via email
7. Use email filtering solutions
8. Keep email software updated

Real-World Example:

Google/Facebook Phishing (2013-2015)

- **Method:** Fake invoices from vendors
- **Loss:** $100 million
- **Lesson:** Even tech giants can be phished

Internet Use Best Practices

Common Internet Threats:

Threat	Description	Prevention
Drive-by Downloads	Malware installed by visiting site	Keep browser updated
Malicious Ads	Infected advertisements	Use ad blocker
Fake Websites	Look legitimate but steal data	Verify URLs
Public Wi-Fi	Unsecured networks	Use VPN

Safe Browsing Tips:

✓ Look for HTTPS in URL

✓ Check for padlock icon

✓ Avoid clicking pop-ups

✓ Don't download from untrusted sites

✓ Use updated browser

✓ Enable browser security features

✓ Use VPN on public Wi-Fi

✓ Log out of sensitive sites

Real-World Example: Firesheep (2010)

- Method: Firefox extension to hijack sessions
- Target: Public Wi-Fi users
- Impact: Facebook, Twitter sessions stolen
- Lesson: HTTPS everywhere is essential

Backup Best Practices

Ensuring Data Recovery

The 3-2-1 Rule:



Type	Description	Pros	Cons
Full	Complete backup	Easy restore	Slow, large
Incremental	Only changes since last backup	Fast, small	Complex restore
Differential	Changes since last full	Medium	Medium

Backup Types:

Real-World Example:

Hurricane Sandy (2012)

- Organizations with offsite backups recovered quickly
- Organizations with only local backups lost data
- **Lesson:** Offsite backups are essential

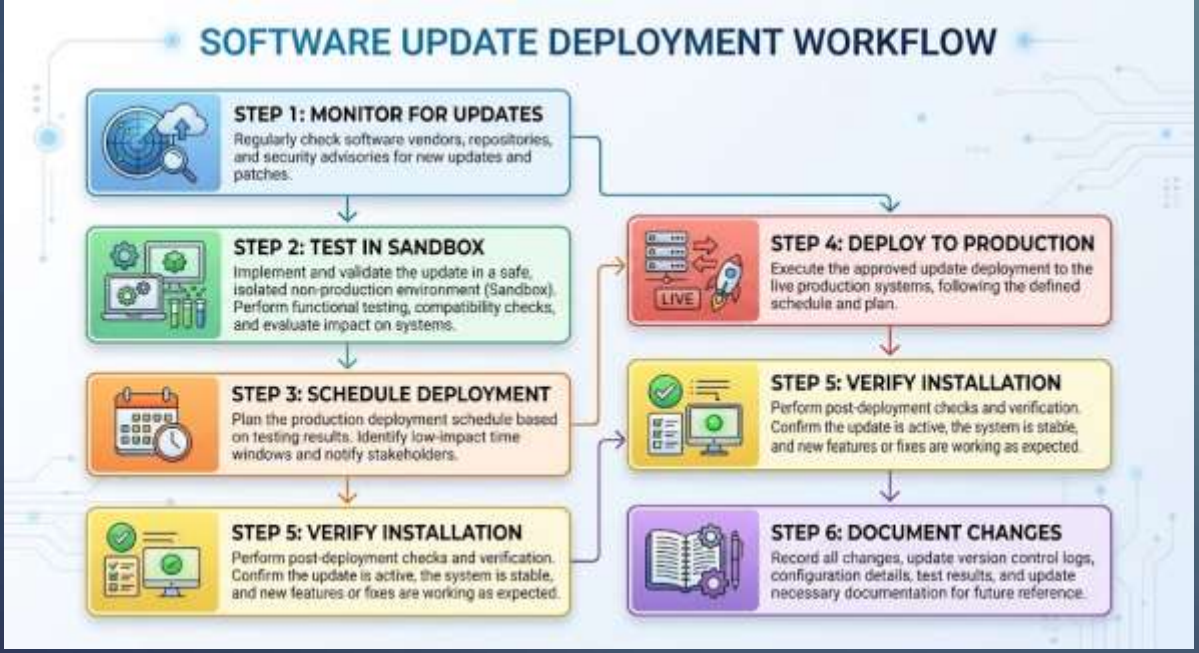
Software Update Best Practices

Patching Vulnerabilities

Update Categories:

Type	Description	Priority
Security Updates	Fix vulnerabilities	Critical
Feature Updates	New functionality	Medium
Bug Fixes	Fix non-security issues	Low

Update Process:



Real-World Example: WannaCry (2017)

- Vulnerability: Windows SMB (EternalBlue)
- Patch Available: March 2017 (MS17-010)
- Impact: 200,000+ systems infected in May 2017
- Lesson: Delayed patching caused massive damage

Security Awareness Programs

"A security awareness program is designed to keep information security at the forefront of users' minds."

Program Components:

Component	Description	Frequency
New Hire Training	Initial security orientation	On hire
Annual Refresher	Update on policies and threats	Yearly
Phishing Simulations	Test user awareness	Quarterly
Security Newsletters	Tips and updates	Monthly
Poster Campaigns	Visual reminders	Ongoing
Lunch and Learns	Informal education	Monthly

Real-World Example: Google's Phishing Quiz

- Interactive quiz to test phishing detection
- 10 questions with immediate feedback
- Result: Improved detection rates by 40%

Security Awareness - Poster Example



Security Training - Phishing

Type	Description	Target
Mass Phishing	Generic emails	Many recipients
Spear Phishing	Targeted emails	Specific individuals
Whaling	Targeting executives	CEOs, CFOs
Vishing	Voice phishing	Phone users
Smishing	SMS phishing	Mobile users

⚠ URGENCY: "Act now or your account will be closed"
⚠ THREATS: "Your account has been compromised"
⚠ TOO GOOD: "You've won a prize!"
⚠ GENERIC: "Dear Customer"
⚠ MISMATCH: Sender doesn't match company
⚠ LINKS: Hover to see actual URL
⚠ ATTACHMENTS: Unexpected files
⚠ GRAMMAR: Spelling and syntax errors
⚠ REQUESTS: Passwords, credit cards
⚠ TIMING: Unusual sending time

Real-World Example:
Twitter Bitcoin Scam (2020)

- Compromised accounts of Elon Musk, Barack Obama, Bill Gates
- Message: "Send Bitcoin, get double back"
- Loss: $120,000
- Lesson: Even verified accounts can be compromised

Security Training - Social Engineering

Common Techniques:

Technique	Description	Example
Pretexting	False scenario	"I'm from IT, need your password"
Tailgating	Following authorized person	Entering behind badge holder
Shoulder Surfing	Looking over shoulder	Reading passwords
Dumpster Diving	Searching trash	Finding documents
Quid Pro Quo	Offering something	"Free gift for survey"
Baiting	Leaving infected media	USB in parking lot

Defense Strategies:

1. Verify identities before sharing information
2. Don't trust caller ID
3. Escort visitors
4. Lock your computer when away
5. Shred sensitive documents
6. Report suspicious activity
7. Follow security policies
8. When in doubt, ask!

Real-World Example: Kevin Mitnick

- Method: Social engineering, not technical hacking
- Success: Accessed Pentagon, Pacific Bell, FBI
- Quote: "People are the weakest link"
- Lesson: Social engineering bypasses all technical controls

Business Continuity Planning

"Business continuity planning prepares an organization to reestablish critical business operations during a disaster that affects operations at the primary site."

Key Components:

Component	Description	Example
Business Impact Analysis	Identify critical functions	Order processing
Recovery Strategies	How to recover	Alternate site
Plan Development	Document procedures	BC plan document
Testing and Training	Practice the plan	Annual drills
Maintenance	Keep plan current	Quarterly reviews

Real-World Example:
Amazon Web Services Outage (2017)

- Impact: Many websites down for hours
- Organizations with BC plans: Switched to backup regions
- Organizations without: Waited for restoration
- Lesson: BC planning enables quick recovery

Disaster Recovery Planning

"Disaster recovery planning is the process of preparing an organization to handle and recover from a disaster, whether natural or man-made."

DR Plan Components:

Component	Description	Example
Priorities	What to recover first	Life safety, then data
Roles	Who does what	DR team assignments
Notification	Who to call	Alert roster
Documentation	Record everything	Incident log
Recovery Procedures	Step-by-step actions	Restore from backup

Disaster Types:

NATURAL:

- Fire
- Flood
- Earthquake
- Hurricane
- Tornado

MAN-MADE:

- Cyber attack
- Terrorism
- Power outage
- Human error
- Sabotage

DR Planning - Real World Example

Hurricane Katrina Response

Organization A (With DR Plan):

- **Before:** Documented DR plan, tested annually
- **During:** Activated alternate site within 24 hours
- **After:** Resumed operations in 3 days
- **Result:** Minimal business impact

Organization B (Without DR Plan):

- **Before:** No documented plan
- **During:** Scrambled to find alternate site
- **After:** Took 6 weeks to resume operations
- **Result:** Lost customers, revenue, reputation

Key Differences:

Aspect	Organization A	Organization B
Preparation	Annual testing	None
Response Time	24 hours	1 week
Recovery Time	3 days	6 weeks
Business Impact	Minimal	Severe

Continuity Strategies

Site Types:

Type	Description	Recovery Time	Cost
Hot Site	Fully configured, ready to use	Minutes	Very High
Warm Site	Partially configured	Hours-Days	Medium
Cold Site	Empty facility	Weeks	Low
Mobile Site	Trailer with equipment	Days	Medium

Shared Options:

Option	Description	Pros	Cons
Time-share	Shared with partner	Lower cost	Availability risk
Service Bureau	Third-party provider	Professional	Expensive
Mutual Agreement	Reciprocal with another org	Low cost	May not be available

Real-World Example: Financial Services Firm

- Primary: Hot site (for critical systems)
- Secondary: Warm site (for non-critical)
- Backup: Cold site (for long-term recovery)
- Lesson: Different systems need different strategies

Data Backup Strategies

Protecting Critical Data

Backup Types:

Type	Description	Storage Required	Restore Speed
Full	Complete copy of all data	High	Fast
Incremental	Only changes since last backup	Low	Slow
Differential	Changes since last full backup	Medium	Medium

Backup Rotation Schemes:

Grandfather-Father-Son:

Week 1: Tapes A1, A2, A3, A4, A5 (daily)

Week 2: Tapes B1, B2, B3, B4, B5 (daily)

Week 3: Tapes C1, C2, C3, C4, C5 (daily)

Week 4: Reuse A1-A5

...

Monthly: Archive one set for long-term storage

Backup Rotation Schemes:

Towers of Hanoi:

Day 1: Tape A

Day 2: Tape B

Day 3: Tape A

Day 4: Tape C

Day 5: Tape A

Day 6: Tape B

Day 7: Tape A

Day 8: Tape D

...

Offsite Data Storage

Getting Data to Safety

Storage Options:

Option	Description	Recovery Time
Electronic Vaulting	Batch transfer to offsite	Hours
Remote Journaling	Real-time transaction transfer	Minutes
Database Shadowing	Real-time database duplication	Seconds

Real-World Example:
Banking Transaction System

Electronic Vaulting:
- Every night, all transactions transferred to offsite
- Recovery: Restore from last night's data

Remote Journaling:
- Every transaction sent to offsite in real-time
- Recovery: Replay transactions from point of failure

Database Shadowing:
- Multiple copies of database maintained
- Recovery: Switch to alternate database instantly

Incident Response

- Incident Response (IR) is a structured approach to identifying, containing, eradicating, and recovering from cybersecurity incidents (e.g., breaches, ransomware, insider threats). It aims to minimize damage and restore normal operations swiftly.
- Events
- What are incidents?
- **False positive**: A security solution raised an alert on a high amount of data being transferred from one system to an external IP address. Upon analyzing this alert, the security team found that the subject system was undergoing a backup process to a cloud storage service, which caused this. This is known as a false positive.
- **True Positive**: A security solution raised an alert on a phishing attempt on one of the organization's users. Upon analyzing this alert, the security team found that the email was a phishing email sent to this user to compromise the system. This is known as a true positive.
- Types of Incidents:

  Malware Infections, Security Breaches, Data Leaks, Insider Attacks, Denial Of Service Attacks

Incident Response Process: SANS

Phase	Explanation	Example
Preparation	This is the first phase. The preparation phase includes building the necessary resources to handle an incident. These resources include developing incident response teams, having a proper incident response plan in place, and deploying necessary security solutions to combat the incidents.	Conducting awareness training for employees on phishing emails. Phishing emails are fraudulent emails sent by malicious attackers that can trick you into performing actions that can lead you to an incident.
Identification	The identification phase refers to looking for any abnormal behavior that may indicate an incident. This involves using various security solutions and techniques to monitor abnormal events.	The security team notices a huge amount of data being sent out from one of the hosts. Upon analysis, it was found to be compromised after a malicious file was downloaded from a phishing email attachment.
Containment	Once an incident has been identified, the next step should be to contain it. This means minimizing the impact of the attack. This is usually done by isolating the victim machine, disabling the compromised user accounts, etc.	The Security team isolates the host from the network to minimize the impact and not allow the attacker to jump to other systems, leveraging the compromised host.
Eradication	This phase, as its name suggests, involves removing the threat from the attacked environment. The threat may be of any kind. The eradication phase will ensure the subject environment is clean, and now we can move to the recovery phase.	A deep malware scan was executed on the system to remove the malicious software from the host.
Recovery	The recovery phase is very important in this chain. It involves recovering the affected systems from backup or rebuilding them. The recovered systems are then tested and are ready to use.	The compromised host was re-configured, and the exfiltrated data was restored from the backup.
Lessons Learned	This is also an important part of the incident response lifecycle. Gaps in the detection and analysis of the incident are identified and documented, helping to improve the overall process in future incidents.	Conducting a post-incident review meeting to analyze the incident's root cause and improve the security to prevent future attacks.

Incident Response



- Incident Response Techniques
- IR Playbook

After incidents are identified, certain procedures must be followed, including investigating the extent of the attack, taking necessary actions to prevent further damage and eliminate it from the root. These steps may be different for different kinds of incidents. In this scenario, having step-by-step instructions to deal with each kind of incident helps you save a lot of time. These types of instructions are known as Playbooks. It ensures consistent, efficient responses during high-pressure situations (e.g., ransomware, data breaches).

Incident Response - Real World

Case Study: Ransomware Attack

Time	Event	Action
09:00	User reports slow computer	Help desk ticket created
09:15	Multiple users report issues	Incident declared
09:30	IR team assembled	Initial assessment
10:00	Ransomware identified	Containment started
11:00	Systems isolated	Eradication begins
12:00	Systems cleaned	Recovery starts
14:00	Systems restored	Monitoring begins
16:00	Incident closed	Report prepared

Lessons Learned:

1. Detection time matters — 15 minutes saved hours
2. Containment is critical — Isolated systems prevented spread
3. Backups are essential — Restored without paying ransom
4. Communication is key — Regular updates reduced panic
5. After-action review — Improved future response

Crisis Management

"Crisis management differs dramatically from incident response, as it focuses first and foremost on the people involved."

Activity	Description	Example
Personnel Support	Help employees and families	Counseling, shelter
Impact Assessment	Determine business impact	Revenue loss
Public Communication	Keep public informed	Press releases
Stakeholder Communication	Notify customers, partners	Emails, calls



Discussion Questions

Why is security planning a management problem rather than a technical one?

What are the key differences between EISP, ISSP, and SysSP?

How would you implement a security awareness program in your university?

What backup strategy would you recommend for a small business? Why?

How does PECA 2016 affect organizations in Pakistan?

What are the most critical components of a disaster recovery plan?

Why do many organizations fail to test their disaster recovery plans?

How can organizations balance security with usability in their policies?

Thank you